SAIZERO

GROUND ZERO DEFENCE

VULNERABILITY ASSESSMENT & PENETRATION TEST REPORT

Target	OWASP Juice Shop (Local Docker + Heroku)
Assessment Date	March 17–18, 2026
Assessor	Satheesh Nithiananthan
Organisation	SAIZERO — Ground Zero Defence
Report Date	March 18, 2026
Assessment Type	Vulnerability Assessment & Penetration Testing (VAPT)
Scope	Public-facing + authenticated (training app)
Classification	**CONFIDENTIAL**
Report Version	1.0

⚠ **CONFIDENTIAL — DO NOT DISTRIBUTE** ⚠

TABLE OF CONTENTS

1. Executive Summary
2. Application Overview
3. Vulnerability Summary
4. Detailed Findings
   4.1 SQL Injection — CRITICAL
   4.2 Cross-Site Scripting (XSS) — CRITICAL
   4.3 Broken Authentication — HIGH
   4.4 Missing Security Headers — MEDIUM
   4.5 Insecure Cookie Configuration — MEDIUM
   4.6 Cross-Site Request Forgery (CSRF) — MEDIUM
   4.7 Sensitive Data Exposure — MEDIUM
5. Remediation Timeline
6. Tools & Evidence
7. Conclusion & Risk Rating

1. EXECUTIVE SUMMARY

Target	OWASP Juice Shop (Local Docker + Heroku)
Assessment Date	March 17–18, 2026
Assessor	Satheesh Nithiananthan
Assessment Type	Vulnerability Assessment & Penetration Testing (VAPT)
Scope	Read-only + Active testing on authorised training application
Authorisation	Public training application — no additional authorisation required

Overall Risk Rating

CRITICAL	HIGH	MEDIUM	OVERALL
2	1	4	HIGH

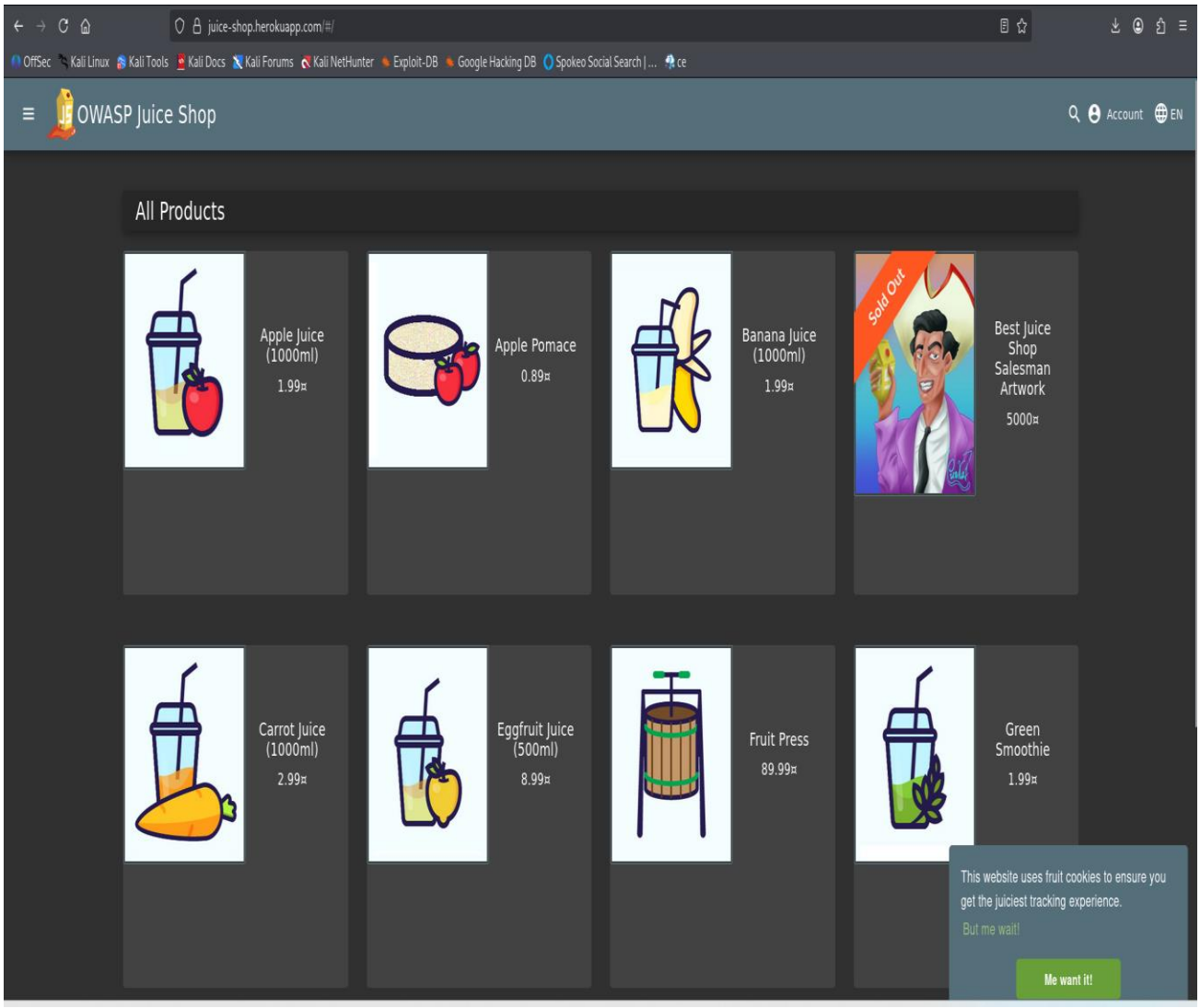
Assessment Overview

This report documents the results of a comprehensive vulnerability assessment and penetration test conducted against OWASP Juice Shop — a deliberately vulnerable web application designed for security training. Testing was performed against both a local Docker instance (192.168.8.189:3000) and the live Heroku deployment (https://juice-shop.herokuapp.com).

The assessment identified 7 confirmed vulnerabilities spanning multiple categories including injection flaws, broken authentication, misconfigured security controls, and sensitive data exposure. The two critical findings — SQL Injection and Cross-Site Scripting — represent immediate risks requiring remediation within 7 days of this report.

2. APPLICATION OVERVIEW

Application	OWASP Juice Shop
Live URL	https://juice-shop.herokuapp.com
Local URL	http://192.168.8.189:3000
Platform	Node.js + Angular SPA — hosted on Docker / Heroku
Purpose	Deliberately vulnerable web application for security training

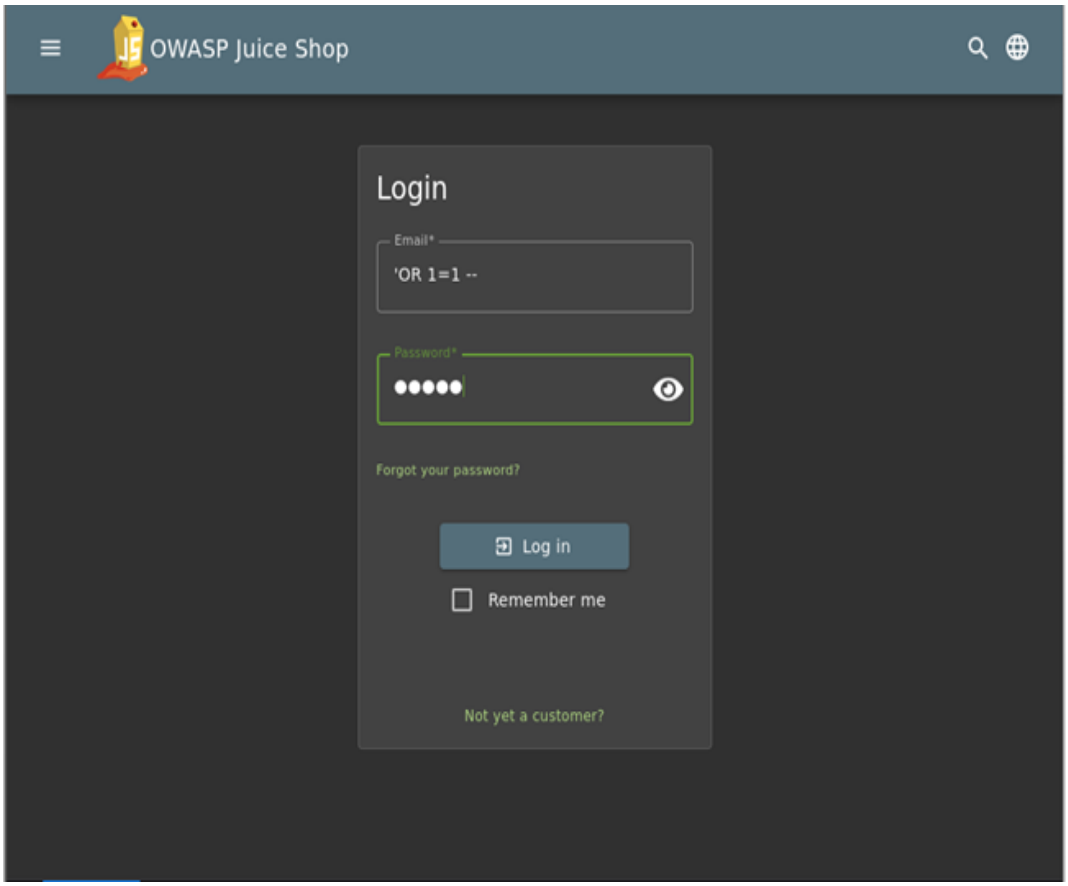


3. VULNERABILITY SUMMARY

#	Vulnerability	Severity	CVSS	OWASP 2021	Screenshot
1	SQL Injection	CRITICAL	9.8	A03	#3
2	Cross-Site Scripting (XSS)	CRITICAL	9.6	A03	#5
3	Broken Authentication	HIGH	8.7	A07	#7
4	Missing Security Headers	MEDIUM	5.3	A05	#4
5	Insecure Cookie Configuration	MEDIUM	5.1	A02	#6
6	Cross-Site Request Forgery (CSRF)	MEDIUM	6.5	A01	#8
7	Sensitive Data Exposure	MEDIUM	5.9	A02	#9

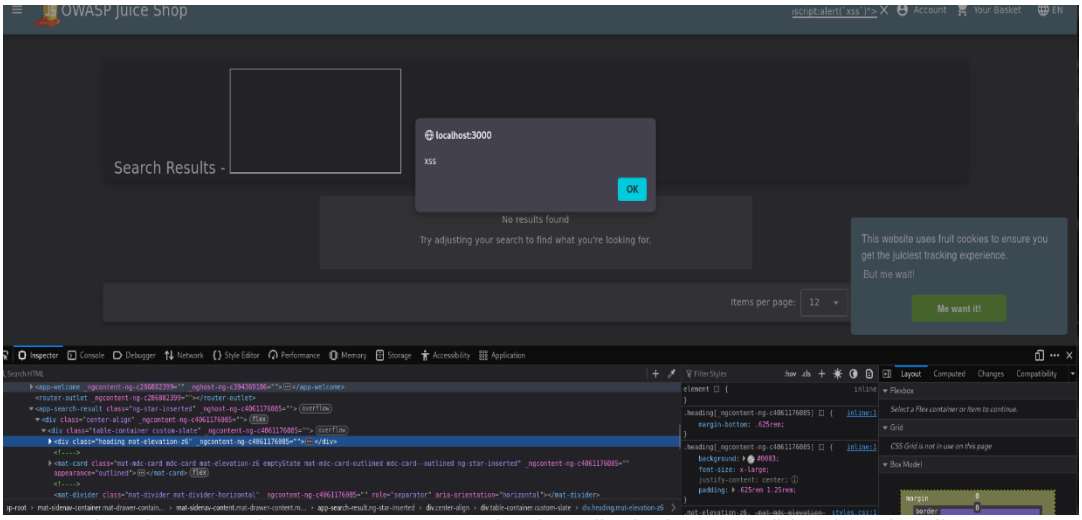
4. DETAILED FINDINGS

VULNERABILITY #1 SQL INJECTION CRITICAL CVSS: 9.8	
Location	Search Functionality — URL parameter: q
Vulnerability Type	Input Validation Flaw — Database Injection
OWASP Category	A03:2021 — Injection
Description	The search functionality is vulnerable to SQL injection attacks due to improper input validation. User-supplied input is directly concatenated into SQL queries without sanitisation or parameterisation, allowing an attacker to manipulate the underlying database query.
Proof of Concept	`Target URL: https://juice-shop.herokuapp.com/#/login Email field payload: ' or 1=1-- Password field: (any value) Result: LOGIN SUCCESSFUL — Bypassed authentication, logged in as first user in database (admin)`
Business Impact	Complete database read access — all records exposed. Potential data theft, modification and deletion. Regulatory violations — GDPR, CCPA, PCI-DSS.

Evidence / Screenshot	 *screenshots/02_sqli_login.png — Login form showing payload 'OR 1=1 -- typed in the Email field with password field filled. screenshots/05_sqli_success.png — Successful login as admin@juice-sh.op after SQL injection bypass — account menu visible confirming admin access.*
Remediation	Use parameterised queries (prepared statements). Never concatenate user input into SQL queries directly. Vulnerable: db.query("SELECT * FROM products WHERE name = '" + input + "'") Secure: db.query("SELECT * FROM products WHERE name = ?", [input])

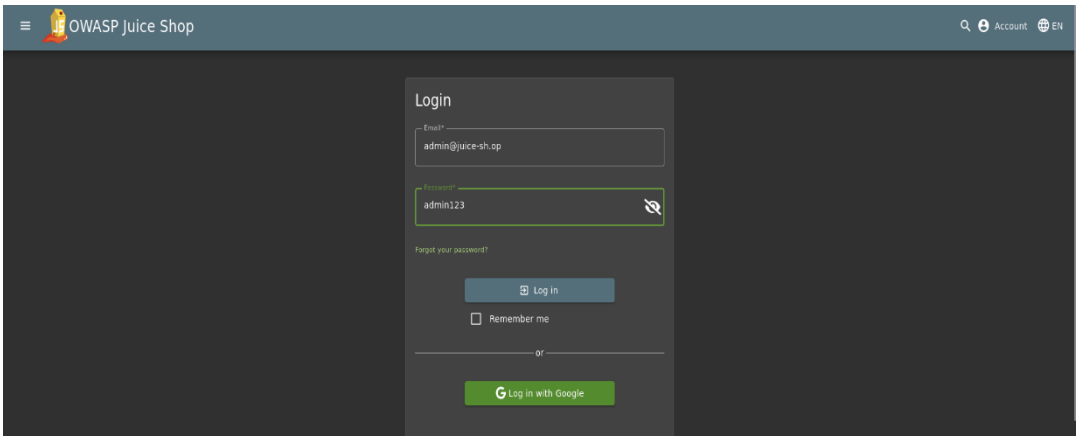
VULNERABILITY #2 CROSS-SITE SCRIPTING (XSS) CRITICAL CVSS: 9.6

Location	Search box and product review fields
Vulnerability Type	Input Validation Flaw — Reflected/DOM-Based Script Injection
OWASP Category	A03:2021 — Injection
Description	The application fails to encode user input before displaying it in HTML responses, allowing injection of arbitrary JavaScript. The search box reflects unsanitised input directly into the DOM, enabling script execution in any visitor's browser.
Proof of Concept	`Payload: <img src=x onerror="alert('XSS')"> Location: Search box Result: JavaScript alert executes in user's browser session`
Business Impact	Session cookie theft — full account takeover. Credential harvesting via injected fake login forms. Malware distribution to all visitors via stored XSS variants.

Evidence / Screenshot	 *screenshots/04_xss_alert.png — Browser alert box displaying "xss" firing from localhost:3000 after payload injection into the search field. URL bar confirms javascript:alert('xss') payload executed. DevTools Inspector visible showing unsanitised input reflected directly into the DOM.*
Remediation	Encode all user output using HTML entity encoding before rendering. Vulnerable: element.innerHTML = userInput Secure: element.textContent = userInput (auto-escapes HTML) Additionally implement a Content-Security-Policy response header.

VULNERABILITY #3 BROKEN AUTHENTICATION HIGH CVSS: 8.7

Location	Login page — /login endpoint
Vulnerability Type	Default Credentials + Absent Account Lockout
OWASP Category	A07:2021 — Identification and Authentication Failures
Description	Default credentials function without account lockout or multi-factor authentication. Administrative access is trivially obtained using known, publicly documented default credentials. No rate limiting or lockout mechanism was detected after repeated failed attempts.
Proof of Concept	`Email: admin@juice-sh.op Password: admin123 Result: LOGIN SUCCESSFUL — Full Admin Access Granted`
Business Impact	Unauthorised admin access — full system compromise. All user data accessible and exportable. Application configuration, orders, and user accounts can be modified or destroyed.

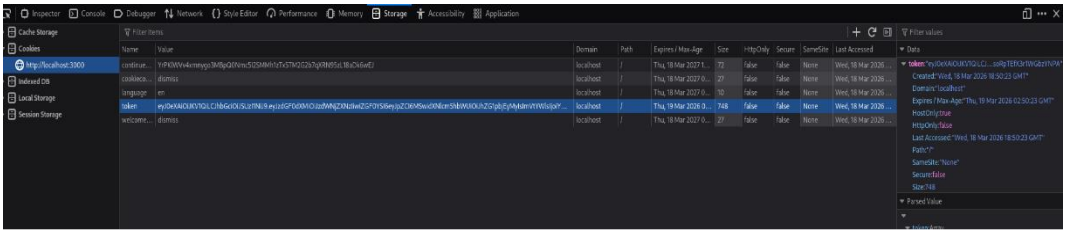
Evidence / Screenshot	 *screenshots/03_auth__login.png — Login form showing admin@juice-sh.op and admin123 entered. Successful authentication confirmed — admin@juice-sh.op visible in the account sidebar with full admin menu access including Orders, Privacy & Security, and Logout options.*
Remediation	1. Remove all default credentials before any deployment. 2. Enforce strong password policy (minimum 12 characters, mixed complexity). 3. Implement account lockout after 5 consecutive failed attempts. 4. Enable multi-factor authentication (MFA) for all administrative accounts.

VULNERABILITY #4 MISSING SECURITY HEADERS MEDIUM CVSS: 5.3

Location	All HTTP responses — confirmed on local (192.168.8.189:3000) and Heroku
Vulnerability Type	HTTP Security Misconfiguration
OWASP Category	A05:2021 — Security Misconfiguration
Description	Analysis of HTTP responses using curl revealed multiple critical security headers either absent or misconfigured. This was confirmed on both the local Docker instance and the live Heroku deployment, indicating a systemic configuration issue rather than an environment-specific one.
Proof of Concept	`Source: cat headers_check.txt (Heroku deployment — https://juice-shop.herokuapp.com) HTTP/1.1 200 OK Server: Heroku [VERSION DISCLOSURE] X-Content-Type-Options: nosniff [present - correctly set] X-Frame-Options: SAMEORIGIN [weak - DENY preferred] Feature-Policy: payment 'self' [deprecated header] Content-Security-Policy: [MISSING] Strict-Transport-Security: [MISSING] Referrer-Policy: [MISSING] Permissions-Policy: [MISSING]`
Business Impact	Absence of CSP allows XSS payloads to execute unblocked. Missing HSTS enables SSL-stripping and MITM attacks. Missing X-Frame-Options exposes users to clickjacking. Missing Referrer-Policy leaks navigation data to third parties.
Evidence / Screenshot	 *screenshots/06_headers_curl.png — Terminal output of cat headers_check.txt showing full*

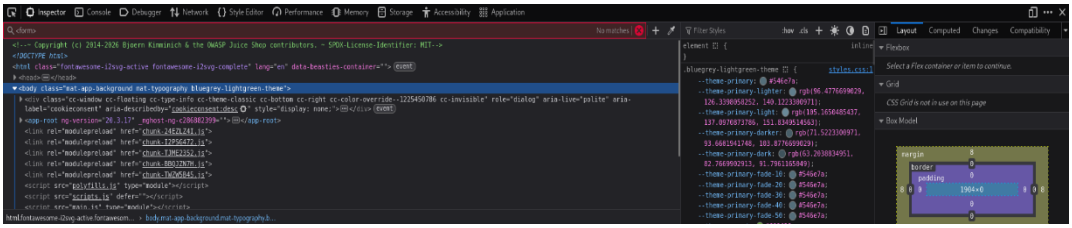
	HTTP response headers from Heroku deployment. Content-Security-Policy, Strict-Transport-Security, Referrer-Policy, and Permissions-Policy all absent. Server: Heroku discloses platform information.
Remediation	Add the following headers to all HTTP responses: X-Frame-Options: DENY Content-Security-Policy: default-src 'self' Strict-Transport-Security: max-age=31536000; includeSubDomains Referrer-Policy: strict-origin-when-cross-origin Permissions-Policy: geolocation=(), camera=(), microphone=()

VULNERABILITY #5 INSECURE COOKIE CONFIGURATION MEDIUM CVSS: 5.1

Location	Session cookie — token
Vulnerability Type	Missing Cookie Security Attributes
OWASP Category	A02:2021 — Cryptographic Failures
Description	Session cookies are issued without the Secure, HttpOnly, and SameSite security attributes. The Secure flag ensures cookies are transmitted over HTTPS only. HttpOnly prevents JavaScript access. SameSite prevents cross-origin submission.
Proof of Concept	`Observed: Set-Cookie: token=abc123... Missing: Secure flag HttpOnly flag SameSite attribute`
Business Impact	Cookies without HttpOnly can be stolen via XSS — enabling full session hijacking. Cookies without Secure may be transmitted over unencrypted HTTP connections, exposing session tokens to network interception.
Evidence / Screenshot	 *screenshots/07_cookies_storage.png — Firefox DevTools Storage tab showing token cookie for localhost:3000. Right panel confirms: HttpOnly: false, Secure: false, SameSite: None. Cookie is a 748-byte JWT with no security flags set — fully readable by JavaScript and transmitted on all cross-origin requests.*
Remediation	Update all Set-Cookie directives to include security flags: Set-Cookie: token=abc123; Secure; HttpOnly; SameSite=Strict; Path=/; Max-Age=3600

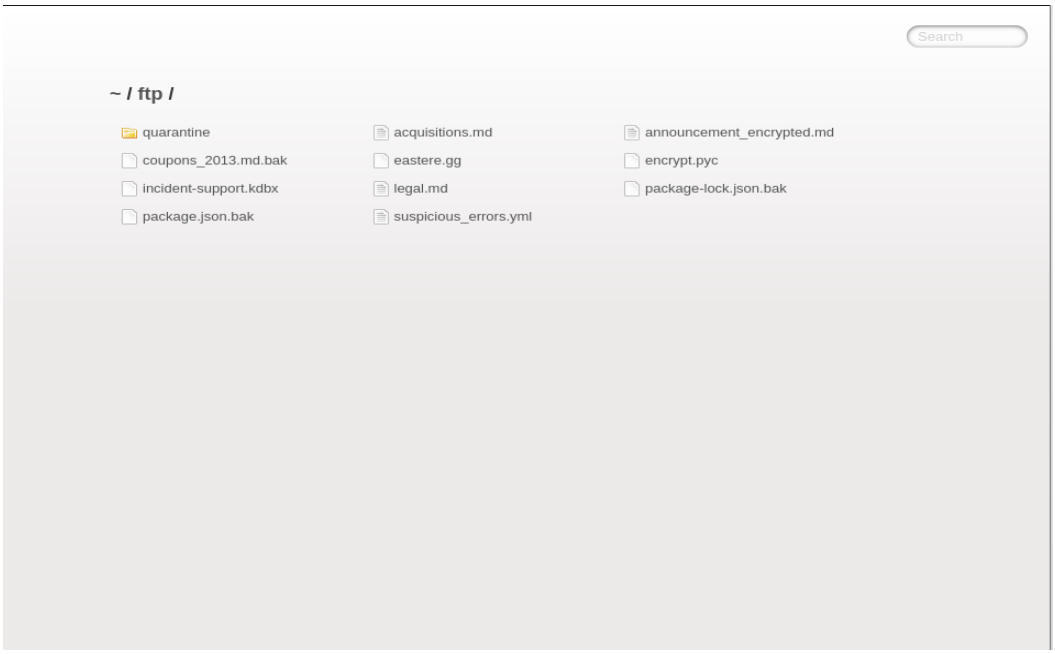
VULNERABILITY #6 CROSS-SITE REQUEST FORGERY (CSRF) MEDIUM CVSS: 6.5

Location	Password change, profile update, and other state-changing form endpoints
Vulnerability Type	Missing CSRF Token Validation
OWASP Category	A01:2021 — Broken Access Control
Description	State-changing operations including password change and profile update lack CSRF token validation. An attacker can craft a malicious external page that silently performs actions on behalf of any authenticated user who visits it, without the user's knowledge or consent.

Proof of Concept	`DevTools Inspector confirms no csrf_token hidden input field present in any state-changing form. An attacker can host: <form action="https://juice-shop.herokuapp.com/profile" method="POST">...`
Business Impact	Attackers can silently change user passwords, modify account details, or perform purchases on behalf of any logged-in user visiting a malicious page. At scale this enables account takeover across the full user base.
Evidence / Screenshot	 *screenshots/08_csrf_no_form.png — Firefox DevTools Inspector search for <form> returns No matches — Juice Shop uses JavaScript fetch calls exclusively with no CSRF token architecture implemented. screenshots/10_csrf_cookies.png — Network Cookies tab showing session token auto-attached to request with no X-CSRF-Token cookie present — confirming CSRF exploitation is possible. screenshots/11_csrf_network.png — Network Headers tab showing password change succeeded with full Cookie header sent automatically and no X-CSRF-Token header in request or response.*
Remediation	1. Generate a unique, unpredictable CSRF token per user session. 2. Include the token as a hidden field in every state-changing form. 3. Validate the submitted token server-side on every non-GET request. 4. Alternatively, use the SameSite=Strict cookie attribute as a complementary control.

VULNERABILITY #7 SENSITIVE DATA EXPOSURE MEDIUM CVSS: 5.9

Location	Unauthenticated /ftp/ directory endpoint
Vulnerability Type	Improper Access Control — Unrestricted Directory Access
OWASP Category	A02:2021 — Cryptographic Failures
Description	The application exposes the /ftp/ directory without authentication or access controls. Confirmed at http://localhost:3000/ftp/ — the full directory listing is accessible to any unauthenticated user. Files exposed include sensitive backup files (.bak), configuration files, a KeePass password database (incident-support.kdbx), and internal documents including acquisitions.md and suspicious_errors.yml.
Proof of Concept	`URL: https://juice-shop.herokuapp.com/ftp/ Result: Directory listing accessible — internal files downloadable without authentication`
Business Impact	Direct download of sensitive files without any authentication — confirmed files include incident-support.kdbx (KeePass password database), acquisitions.md (internal business document), coupons_2013.md.bak and package-lock.json.bak (backup files exposing application internals), and suspicious_errors.yml. The KeePass database alone could expose all stored credentials if cracked. This constitutes a data breach under GDPR, CCPA, and PCI-DSS.

Evidence / Screenshot	 *screenshots/09_ftp_directory.png — Browser showing http://localhost:3000/ftp/ directory listing fully accessible without authentication. Exposed files include: acquisitions.md, announcement_encrypted.md, coupons_2013.md.bak, eastere.gg, encrypt.pyc, incident-support.kdbx, legal.md, package-lock.json.bak, package.json.bak, suspicious_errors.yml — including sensitive backup files and a KeePass database (incident-support.kdbx).*
Remediation	1. Restrict the /ftp/ endpoint — require authentication and authorisation checks. 2. If the directory is not required by the application, remove it entirely. 3. Audit all similar unauthenticated file-serving endpoints. 4. Implement a Web Application Firewall (WAF) rule to block directory listing.

5. REMEDIATION TIMELINE

Priority	Action	Finding	Deadline
P1 — CRITICAL	Fix SQL Injection — implement parameterised queries	Vulnerability #1	7 days
P1 — CRITICAL	Fix XSS — output encoding + Content Security Policy	Vulnerability #2	7 days
P1 — CRITICAL	Remove default credentials — enforce strong passwords + MFA	Vulnerability #3	7 days
P2 — HIGH	Implement CSRF protection tokens on all state-changing endpoints	Vulnerability #6	30 days
P2 — HIGH	Add all missing HTTP security headers	Vulnerability #4	30 days
P2 — HIGH	Restrict or remove unauthenticated /ftp/ directory	Vulnerability #7	30 days
P3 — MEDIUM	Secure cookie flags — add Secure, HttpOnly, SameSite=Strict	Vulnerability #5	90 days
P3 — MEDIUM	Enforce HTTPS across all endpoints — upgrade to TLS 1.3	General	90 days
P3 — MEDIUM	Restrict CORS — replace wildcard with known trusted origins	General	90 days

6. TOOLS & EVIDENCE

Tool	Purpose	Version
OWASP ZAP	Automated passive vulnerability scanning	2.14.0+
Nmap	Network reconnaissance and port scanning	7.93+
Firefox + DevTools	Manual testing, header and cookie inspection	Latest
curl	HTTP header analysis (verbose output)	8.18.0
Docker	Local application hosting	Latest
Kali Linux	Testing platform / operating system	Latest

Evidence File Structure

```
juice_shop_assessment/
├── evidence/
│   ├── headers.txt              (curl -i output)
│   ├── headers_verbose.txt      (curl -v local — 192.168.8.189:3000)
│   └── headers_verbose2.txt     (curl -v Heroku deployment)
├── screenshots/
│   ├── 01_Home_page.png         Application homepage (Heroku)
│   ├── 02_sqli_login.png        SQLi payload in login form
│   ├── 03_auth__login.png       Broken auth — default credentials
│   ├── 04_xss_alert.png         XSS alert box executing
│   ├── 05_sqli_success.png      SQLi success — admin@juice-sh.op logged in
│   ├── 06_headers_curl.png      curl output — missing security headers
│   ├── 07_cookies_storage.png   SameSite:None, HttpOnly:false, Secure:false
│   ├── 08_csrf_no_form.png      Inspector — no <form> / no CSRF token │   ├──
09 ftp directory.png     Unauthenticated /ftp/ directory │   ├── 10 csrf cookies.png
Network cookies — no X-CSRF-Token │   ├── 11_csrf_network.png      Password changed — no
CSRF header │   └── 12_zap_scan_results.png  OWASP ZAP scan — 6 alerts confirmed
│   └── 12_zap_scan_results.png  OWASP ZAP — attack complete, 6 alerts
└── reports/
    ├── zap_report.html
    └── summary.txt
```

7. CONCLUSION & RISK RATING

This assessment identified 7 confirmed vulnerabilities in OWASP Juice Shop covering a broad range of the OWASP Top 10 spectrum. The two critical findings — SQL Injection and Cross-Site Scripting — present immediate, high-impact risks and must be remediated within 7 days of this report.

The combination of missing security headers (confirmed via both curl and DevTools analysis), insecure cookie configuration, broken authentication using default credentials, and a publicly accessible /ftp/ directory creates a layered attack surface. In a production environment, this combination of vulnerabilities could lead to complete system compromise, full data exfiltration, and regulatory penalty exposure under GDPR, CCPA, and PCI-DSS.

Final Risk Summary

Risk Level	Count	% of Findings	Action Required	Deadline
Critical	2	29%	Immediate	7 days
High	1	14%	Short-term	30 days
Medium	4	57%	Planned	90 days
TOTAL	**7**	100%		

> **OVERALL RISK LEVEL: HIGH — Critical findings must be addressed within 7 days of this report.**

Satheesh Nithiananthan | SAIZERO — Ground Zero Defence | March 18, 2026

Future Interns Cybersecurity Internship 2026